

PCI DSS Compliance Technical Support & Sustainment (AF Installations) Questions and Answers 10 February 2026

#	Questions	Answers
1	Our only question at this time is regarding the Questions and Answers (Q & A) document for Payment Card Industry (PCI) Data Security Standards (DSS) Compliance Technical Support and Tools that was issued last week. Question 1 indicated that scanning hardware is being provided and installed under a separate contract. That effort is currently 70% complete, with full implementation projected for July. Can you clarify what scanning is being done? Is this an effort to determine the size + breadth of networks/devices within scope, or is it a Hardware Asset Management + Monitoring platform? Any information you can provide regarding the tooling already in place will help shape our response to future RFQs.	Can you clarify what scanning is being done? Internal and external network scans and penetration testing. Is this an effort to determine the size + breadth of networks/devices within scope, or is it a Hardware Asset Management + Monitoring platform? The scanning tooling already in place is an asset discovery, inventory, and vulnerability assessment tool.
2	Scans / pen tests / segmentation validation (monitoring vs performing): The SOO emphasizes continuous monitoring (including monitoring scanning and penetration testing dashboards and segmentation validation). We interpret this as our company reviewing/validating results and evidence and driving remediation coordination, not operating as the performing entity for enterprise scanning/penetration testing. Can you confirm this is the intent, or should we also perform vulnerability scanning and/or penetration testing (which we can support if desired)?	Confirmed; as noted in the SOO, Scanning and Penetration Testing is already underway. The request is to provide the critical oversight, analysis, remediation guidance and hands-on technical support to manage the vulnerability lifecycle, not on operating the testing tools themselves.
3	Segmentation implementation vs. segmentation recommendations/validation: The SOO appears to require ongoing segmentation validation as part of continuous monitoring. We interpret our company's role as recommending segmentation improvements (where it reduces risk/scope) and validating segmentation evidence and remediation progress, while implementation remains with local IT/other parties. Can you confirm that segmentation recommendations and validation are in-scope even if segmentation implementation is performed by others?	The main objective is to maintain a secure, efficient, and cost-effective PCI compliance program. AFSVC will receive strategic recommendations to improve the security framework, reduce the scope and cost of compliance assessments, and increase operational efficiency, regardless of segmentation responsibility.
4	Tools scope (CDE-only vs enterprise-wide): The SOO describes recommending solutions that will be implemented and then managed as part of overall PCI program management. We interpret the tools scope as covering all PCI in-scope systems across the 104 locations (payment/CDE systems plus connected/supporting systems relied upon for PCI controls), not only a single CDE enclave. Can you confirm whether AFSVC intends the tools requirement to apply enterprise-wide to all PCI in-scope systems versus CDE-only?	To clarify, the current strategic objective is to deploy enterprise-provided security and management tools specifically within the confines of the Cardholder Data Environment (CDE) at each respective installation. While the operational scope of the tools is localized to each CDE, they will be integrated into a centralized reporting framework. This will provide a comprehensive, enterprise-level view of the security and compliance posture across all locations.
5	Architecture and openness to optimization recommendations: The SOO references the current payment stack (Aloha POS + Ingenico Move 5000) and existing enterprise technologies (e.g., IBM QRadar / Trellix). We can operate within AFSVC's existing systems and constraints and leverage current tools where appropriate to reduce cost and level of effort. As part of our PCI program experience, we also identify targeted optimization opportunities, where appropriate to improve security and materially reduce CDE footprint and PCI assessment scope (and therefore reduce ongoing annual assessment effort and cost) while maintaining compliance. Is AFSVC open to our company providing those tool/architecture upgrade recommendations for consideration as part of this requirement?	The primary objective is to achieve and maintain a robust, efficient, and cost-effective PCI compliance posture. Strategic recommendations that align with this goal are welcomed. This includes, but is not limited to, suggestions that would: - Enhance the overall security framework. - Materially reduce the CDE footprint and PCI assessment scope. - Decrease the long-term effort and cost associated with annual assessments. - Improve operational efficiency while maintaining full compliance.
6	Procurement model + representative site sizing: We assume AFSVC will procure tools/licensing and our company will implement/configure and manage the selected solution(s), unless intended otherwise. Can you confirm the expected procurement model (AFSVC/Government-procured vs contractor-procured/resold), and provide (or confirm) a representative installation sizing baseline (endpoints/servers, log volume, privileged users, number of networks/CDE segments) so estimates for Phases 2--3 are comparable across offerors?	1. Procurement: AFSVC will be directly responsible for the procurement of all necessary software, hardware, and licensing for the solutions. 2. Implementation & Management: The contractor will be responsible for the implementation (or implementation guidance), configuration, and ongoing management of the Government-furnished tools. 3. The specific technical support, monitoring, and management requirements that define the ongoing role are detailed in the Statement of Objectives (SOO), section 4.1.2. 4. Sizing: We expect experienced vendors to leverage their expertise from similar enterprise-level PCI programs to inform a proposed architecture and support structure.
7	24/7 support model + 1-hour suspected incident reporting trigger: The SOO requires 24/7 support and 1-hour reporting for suspected incidents. We can support the model AFSVC prefers; to ensure we align staffing and response workflows, can you confirm whether "24/7 support" is intended as tool/platform support, managed monitoring/triage, and/or incident response coordination, and what specifically triggers the 1-hour notification requirement (vendor detection vs customer report; suspected vs confirmed)?	The "24/7 support" requirement is comprehensive. It encompasses all operational security functions necessary to ensure the continuous monitoring and protection of the Cardholder Data Environment (CDE). While we are open to operational model and staffing structure proposals, it must deliver on the core capabilities around-the-clock. Incidents should be reported to AFSVC within an hour of identification: 1. Trigger Condition (Suspected vs. Confirmed): The requirement is to report suspected incidents, not confirmed ones. We expect to be notified before a full investigation is complete. The purpose is to alert our leadership and mobilize internal resources, not to receive a complete forensic report. 2. Source of Detection (Vendor vs. Customer): The trigger is agnostic to the source of detection. The one-hour clock begins the moment there is awareness of a potential incident.
8	Which installations are in-scope + prioritization approach: The Sustainment SOO states technical support is needed for roughly one-third of installations and estimates 20--30% of 104 locations lack required IT resources. We can support any rollout model; can AFSVC confirm how in-scope installations will be identified and prioritized (e.g., transaction volume, risk, readiness, geography) and whether a phased execution approach is preferred?	In scope installations are determined by a risk-based assessment focused on whether or not they have on-site IT support, have gaps in IT skills or support, or are geographically separated (remote and isolated). A current state list will be provided upon contract award.
9	Access constraints vs implementation expectations: The Tools SOO notes contractor personnel shall not be assigned duties requiring "Limited Privileged Access" (system/database admin). Meanwhile, the Sustainment SOO expects hands-on technical support activities (e.g., system hardening/configuration, remediation). We interpret this as our company providing expert guidance/configuration support through approved methods while AFSVC/base IT or other approved personnel execute privileged actions as needed. Can you confirm how AFSVC wants privileged changes executed in practice (AF/vendor-led with our company's oversight vs another approved model)?	Correct, the contractor team will provide expert, hands-on guidance and remediation support, while designated government personnel execute the privileged actions. This model ensures we adhere to the Principle of Least Privilege while fully leveraging vendor technical expertise to direct and secure our environment. Vendor will be expected to lead all technical activities short of the final, privileged execution.
10	Given the complexity of PCI challenges and industry recommended tools and enterprise solutions, we recommend the government evaluates proposals based on the strength of technical solution rather than lowest price technically acceptable so the government can procure best-in-class solutions and therefore reduce risk to the government.	This is a competitive Lowest Price Technically Acceptable (LPTA) Request for Quote (RFQ) in which price is considered the most important factor for Contractors deemed technically acceptable. This is a Firm-Fixed Price Contract, however, if there are areas of this requirement where FFP is not beneficial to the Government we are open to any suggestions from the industry.
11	4.0 Deliverables and Acceptance Criteria. Section 4.0 requires offerors to define the list of deliverables, FTEs, labor rates, and timelines as part of the proposal, stating this section will be updated based on the selected solution. With a fixed-firm price (FFP) contract structure, we recommend the government removes the following requirements for each deliverable: -Experience with implementation of each deliverable with Points of Contact (POC) -Number, type and amount of time for FTE to implement each deliverable -Labor Rates of each person assigned to each deliverable -Implementation timeline for each deliverable, if concurrent with another deliverable, please annotate -Full implementation timeline of all deliverables combined w/Total cost of project -Summary of experience with DoD and Federal entities, to include agency, scope of work, and outcome description whether successful or unsuccessful.	See updated SOO.